Clause checklist

Business: Example Electrical Ltd Date: 23 October 2026

Customers covered by the NIS 2 Directive must address supply chain security, including the security-related aspects of their relationships with suppliers (Art. 21(2)(d)). For cloud, data centre, managed and managed security service providers, online marketplaces and other digital providers, the Commission has listed eight contract contents (Implementing Regulation (EU) 2024/2690, Annex, point 5.1.4); many other customers copy them. Financial customers under DORA must include nine elements in every contract on ICT services and six more where the service supports a critical or important function. This list names each clause, what it means, what a business of your size can accept, what to negotiate, and your position today. The advice columns are interpretation, not legal advice; a contract that matters is read by a lawyer before signing.

Part A · Clauses every customer may bring

No.	Clause	Source	What it means	Accept and negotiate	Your position
K1	Cybersecurity requirements for the supplier	Implementing Regulation (EU) 2024/2690, Annex, point 5.1.4(a)	The customer specifies measures you must keep, sometimes “state of the art” or a standard.	Accept the measures of your self-declaration and the dates of your action plan; replace “state of the art” by a reference to the self-declaration; no standard you do not hold. If the customer passes on point 11.6.2(c) of the Implementing Regulation (periodic password change), agree that a password manager with long unique passwords and multi-factor authentication replaces it, or accept a yearly change for administrator accounts.	B1: Partly: a few rules exist, not as one document · planned by 21 January 2027 · C2: In place: authenticator app · D1: Partly: daily to the NAS in the office, no offline copy · planned by 22 November 2026
K2	Awareness, skills, training, certifications of your staff	Implementing Regulation (EU) 2024/2690, Annex, point 5.1.4(b)	Your staff must be briefed; certifications are sometimes demanded.	Accept a yearly briefing with record; negotiate away certifications per person.	G1: Not yet · planned by 21 January 2027
K3	Background verification of your staff	Implementing Regulation (EU) 2024/2690, Annex, point 5.1.4(c)	Checks on staff who work for the customer.	Accept identity check at hiring and written confidentiality; background checks only as far as national law allows, at the customer's request and cost.	G2: In place
K4	Notification of incidents without undue delay	Implementing Regulation (EU) 2024/2690, Annex, point 5.1.4(d)	You must report incidents that put the customer's systems at risk.	Accept the deadline you can keep at night and on holiday; name the channel and the person; negotiate hour counts that start at your becoming aware.	F1: Within 24 hours of becoming aware, by phone, through the management or the deputy

No.	Clause	Source	What it means	Accept and negotiate	Your position
K5	Right to audit or to receive audit reports	Implementing Regulation (EU) 2024/2690, Annex, point 5.1.4(e)	The customer may inspect you or wants reports.	Accept: evidence list and documents on request, self-declaration yearly, written answers; negotiate on-site audits to once a year, with notice, at the auditing party's cost.	B3: None
K6	Handling of vulnerabilities	Implementing Regulation (EU) 2024/2690, Annex, point 5.1.4(f)	You must fix vulnerabilities in what you deliver.	Software and device suppliers: accept a contact and a deadline. Installers of connected devices or anyone with remote access: accept passing on manufacturer updates and reporting known vulnerabilities without undue delay. Everyone else: "not applicable, we supply and install no software or connected devices".	E4: Not applicable: we supply no software or devices
K7	Subcontracting and requirements for subcontractors	Implementing Regulation (EU) 2024/2690, Annex, point 5.1.4(g)	The customer wants to know and approve your subcontractors and pass requirements down to them.	Accept the list of providers, information before a change and flow-down as far as the provider's terms allow; negotiate approval rights into notification rights.	H1: Partly: known, not as a list · planned by 21 January 2027 · H3: Not yet · planned by 21 April 2027
K8	Obligations at the end of the contract: return and disposal of information	Implementing Regulation (EU) 2024/2690, Annex, point 5.1.4(h)	At termination you return or delete what you received.	Accept return or deletion with written confirmation within an agreed period.	I1: In place
K9	Directory entry: a contact point for security	Implementing Regulation (EU) 2024/2690, Annex, point 5.2	The customer keeps a registry of suppliers with contact points.	Accept: name the responsible person and the deputy with phone and email.	A4: Owner or managing director, +43 660 000 00 01 (example), office@example.at; deputy: office management
K10	Data processing agreement	GDPR, Art. 28(3)	Where you process personal data on the customer's behalf, a contract with the contents of Art. 28(3) is mandatory.	Accept the customer's standard agreement; check that sub-processors and deletion match your provider list.	H2: Partly · planned by 21 January 2027
K11	Liability, penalties, proof of insurance	No legal source; usual in contracts	Caps, contractual penalties, cyber insurance as a condition.	Negotiate a cap, exclude consequential loss, no penalty for a late report made in good faith; show the policy if you have one, do not promise one you do not.	B2: No

Part B · Additional clauses of financial customers (DORA)

Only if the customer is a financial entity (bank, insurer, payment or investment firm). Ask in writing whether the customer classifies your service as supporting a critical or important function; the six clauses of Art. 30(3) apply only then. For a microenterprise as financial entity, the audit rights of Art. 30(3)(e) may be delegated to an independent third party.

Article 30 applies only to contracts on ICT services. By your answer to A7 you supply no ICT services; if a financial customer sends these clauses anyway, you may point this out and ask for them to be removed.

Nine elements of every contract on ICT services (Art. 30(2))

Accept and negotiate: accept what describes your service truthfully; the location clause (DORA 2) needs your provider list; assistance at incidents (DORA 6) within your reporting deadline; cooperation with authorities is standard.

No.	Clause	Source
DORA 1	Description of all functions and ICT services, whether subcontracting is permitted and under which conditions	DORA, Art. 30(2)(a)
DORA 2	Locations (regions or countries) of the services and of data processing, with advance notice before a change	DORA, Art. 30(2)(b)
DORA 3	Availability, authenticity, integrity and confidentiality of data, including personal data	DORA, Art. 30(2)(c)
DORA 4	Access, recovery and return of data in an accessible format at insolvency, discontinuation or termination	DORA, Art. 30(2)(d)
DORA 5	Service level descriptions, including updates and revisions	DORA, Art. 30(2)(e)
DORA 6	Assistance at an ICT incident at no additional cost or at a cost determined in advance	DORA, Art. 30(2)(f)
DORA 7	Full cooperation with the customer's competent and resolution authorities	DORA, Art. 30(2)(g)
DORA 8	Termination rights and minimum notice periods	DORA, Art. 30(2)(h)
DORA 9	Participation in the customer's security awareness programmes and resilience training	DORA, Art. 30(2)(i)

Six more where the service supports a critical or important function (Art. 30(3))

Accept and negotiate: only for services the customer classifies as critical or important. Audit rights and testing participation are the costly clauses: ask for cost sharing, and agree the transition period to what you can deliver. If the financial entity is a microenterprise, ask to delegate audit rights to an independent third party you appoint (Art. 30(3) DORA, last subparagraph).

No.	Clause	Source
DORA 10	Full service level descriptions with quantitative and qualitative targets	DORA, Art. 30(3)(a)
DORA 11	Notice periods and reporting of developments that may affect the service	DORA, Art. 30(3)(b)
DORA 12	Business contingency plans, tested, and ICT security measures in line with the customer's framework	DORA, Art. 30(3)(c)
DORA 13	Participation in the customer's threat-led penetration testing	DORA, Art. 30(3)(d)
DORA 14	Ongoing monitoring: unrestricted access, inspection and audit rights of the customer and its authority	DORA, Art. 30(3)(e)
DORA 15	Exit strategy: a mandatory transition period and migration support	DORA, Art. 30(3)(f)

Generated with the Scutoria Security Evidence Toolkit from the answers of the business. Sources read at the original on 19 October 2026: Directive (EU) 2022/2555, Art. 21(2)(d) and (3); Implementing Regulation (EU) 2024/2690, Annex, points 5.1.4 and 5.2; Regulation (EU) 2022/2554 (DORA), Art. 28(8) and Art. 30(1) to (4); Regulation (EU) 2016/679, Art. 28(3). Read again on 23 October 2026: Directive (EU) 2022/2555, Art. 21; Implementing Regulation (EU) 2024/2690, Art. 1 and Annex, points 5.1.4, 5.2 and 11.6.2; Regulation (EU) 2022/2554, Art. 30. The advice is interpretation. No legal advice.